



**SWAMINARAYAN
UNIVERSITY**
THE RESERVOIR OF ALL KNOWLEDGE

**Faculty of Engineering (Degree)
Semester – 7th**

Subject Name – Information security

Subject Code – BE103707

Faculty Name – Radhika Gokani

CHAPTER - 8

1. Key management and distribution

Key management is one of the most critical aspects of cryptography and information security. It refers to the processes and mechanisms used to **create, store, distribute, update, revoke, and destroy cryptographic keys** in a secure manner. Without proper key management, even the strongest cryptographic algorithms become vulnerable.

1. What is Key Management?

Key management includes all activities related to handling cryptographic keys throughout their lifecycle:

- **Key generation**
- **Key storage**
- **Key distribution**
- **Key usage**
- **Key renewal / rotation**
- **Key revocation**
- **Key destruction**

Good key management ensures confidentiality, integrity, authenticity, and non-repudiation.

2. Key Distribution

Key distribution is the method of securely delivering keys to communicating parties so they can exchange encrypted information.

There are different approaches depending on whether **symmetric** or **asymmetric** cryptography is used.

2.1 Key Distribution in Symmetric Cryptography

In symmetric encryption, the same key is shared by both sender and receiver. The main challenge is: **How to securely share the secret key?**

Methods of Symmetric Key Distribution

1. **Manual key exchange**
 - Physically delivering the key (USB, printed form, courier).
 - Secure but not scalable.
2. **Using a Trusted Third Party (Key Distribution Center – KDC)**

- Used in systems like **Kerberos**.
- KDC generates and shares session keys with parties securely.
- 3. **Using a Pre-shared Master Key**
 - A main key is shared once and used to derive session keys.
 - Common in VPNs and secure channels.
- 4. **Using Public-Key Cryptography**
 - A symmetric session key can be encrypted using the receiver's public key.
 - Used in **SSL/TLS handshake**.

2.2 Key Distribution in Asymmetric Cryptography

In asymmetric (public-key) cryptography, each user has:

- **Public key** (shared openly)
- **Private key** (kept secret)

Public Key Distribution Methods

1. **Public Announcement**
 - Users publish their public keys.
 - Vulnerable to **spoofing** (attacker can replace keys).
2. **Public Key Directory**
 - A directory service stores public keys.
 - Must be protected against tampering.
3. **Public Key Authority**
 - A trusted authority verifies and distributes public keys on demand.
4. **Public Key Infrastructure (PKI)**
 - Uses **Certificate Authorities (CA)** and **Digital Certificates**.
 - Most secure method.
 - Basis for HTTPS, e-commerce, authentication systems.

3. Key Management Requirements

Effective key management must satisfy:

3.1 Security Requirements

- **Confidentiality**
Keys should remain secret from unauthorized users.
- **Integrity**
Keys must not be altered during storage or transmission.
- **Availability**
Authorized users should access keys when needed.
- **Authentication**
Ensures keys came from a legitimate source.
- **Non-repudiation**
Especially for public-key usage and digital signatures.

3.2 Operational Requirements

- Scalability for large networks.

- Efficient key distribution and renewal.
- Secure backup and recovery.
- Clear key lifecycle policies.

2. Symmetric key distribution using symmetric and asymmetric encryptions

Both parties use an existing shared key (called a **master key**) to establish new session keys.

Approach

A **Key Distribution Center (KDC)** or **Trusted Third Party** helps distribute new symmetric keys.

Process

1. Each user shares a **master key** with the KDC.
2. When two users (A and B) want to communicate, A requests a session key from KDC.
3. KDC generates a **session key** (K_s).
4. KDC sends:
 - A copy of K_s encrypted with A's master key.
 - A separate copy of K_s (a "ticket") encrypted with B's master key.
5. A sends the "ticket" to B.
6. Both now have the same session key K_s .

Diagram (Conceptual)

$A \rightarrow KDC$: Request for session key with B

$KDC \rightarrow A$: $\{K_s\}_{K_A} + \{K_s, A\}_{K_B}$

$A \rightarrow B$: $\{K_s, A\}_{K_B}$

Where:

K_A = master key between A & KDC

K_B = master key between B & KDC

Advantages

- Fast (symmetric crypto is efficient)
- Suitable for large private networks (e.g., Kerberos)

Disadvantages

- Requires pre-shared master keys
- KDC becomes a single point of failure
- Not suitable for open/public networks

2. Symmetric Key Distribution Using Asymmetric Encryption (Public-Key Cryptography)

Asymmetric cryptography solves the key distribution problem by using:

- **Public key (shared openly)**
- **Private key (kept secret)**

Process

1. Sender generates a **random symmetric session key** (K_s).
2. Sender encrypts K_s with the receiver's **public key** (PU_b):
3. Cipher = Enc(PU_b , K_s)
4. Sender sends the encrypted session key to the receiver.
5. Receiver decrypts using their **private key** (PR_b):
6. K_s = Dec(PR_b , Cipher)
7. Both now share the symmetric key K_s and use it for fast encryption.

Advantages

- Secure distribution over insecure networks.
- No need for pre-shared secret keys.

- Scales well for global use (e.g., internet).

Disadvantages

- Slower than symmetric methods.
- Relies on Public Key Infrastructure (PKI) to verify public keys.

3. Distribution of public keys

Method	Security	Suitable For	Drawback
Public Announcement	Very Low	Small groups	Spoofing, MITM attacks
Public Key Directory	Medium	Organizations	Directory can be attacked
Public Key Authority	High	Secure networks	Requires online authority
Public Key Certificates (PKI)	Very High	Internet-scale systems	Complex infrastructure

In public-key cryptography, each user has a **public key** and a **private key**.

The **public key** must be widely available so others can use it for encryption or signature verification.

The main challenge is:

☞ **How to securely distribute public keys so that they cannot be replaced or tampered with by attackers?**

There are **four major methods** for public key distribution:

1. Public Announcement

Description

Users simply announce or publish their public keys:

- Through emails
- On a website
- On notice boards
- In forums or public lists

Problem

- **No authentication**
- Vulnerable to **man-in-the-middle attack**
(Attacker can replace the key with their own)

This method is insecure and rarely used in sensitive systems.

2. Public Key Directory

Description

A trusted directory (server) maintains a list of public keys for all users.

Characteristics

- Directory is protected and centrally managed
- Users can access public keys by requesting them

Issues

- Requires directory to be secure
- Needs regular updates
- Users must trust the directory is not compromised

Useful in controlled networks (e.g., universities, companies).

3. Public Key Authority

Description

A **trusted authority** distributes public keys **on demand**.

How it Works

1. User A requests B's public key from the authority.
2. Authority sends the public key **digitally signed** to ensure authenticity.
3. A verifies the authority's signature.
4. Now A trusts the key.

Advantages

- Provides **authentication**
- Harder for attackers to replace keys

Disadvantages

- Authority must be online at all times
- Extra communication required

4. Public Key Certificates (Public Key Infrastructure – PKI)

Description

A **Certificate Authority (CA)** issues a digital certificate that contains:

- Public key of the user
- User's identity
- CA's digital signature

How it Works

1. The user sends their public key to the CA.
2. CA verifies identity and issues a **digital certificate**.
3. Users share certificates, not raw public keys.
4. Anyone can verify the certificate using CA's public key.

Advantages

- Highly secure
- Scalable for large networks
- Standard for **HTTPS, SSL/TLS, e-commerce, banking**

4. X.509 certificates

In **X.509 certificate** is a widely used standard for **public key certificates**.

It is defined by the **ITU-T X.509** standard and is a core component of **Public Key Infrastructure (PKI)**.

X.509 certificates are used to:

- Bind a public key to an identity (person, organization, server)
- Enable secure communication
- Authenticate users and devices
- Establish trust over insecure networks (e.g., Internet)

Most modern secure systems (HTTPS/SSL/TLS, email security, digital signatures) rely on X.509 certificates.

Key Features

- Digitally signed by a **Certificate Authority (CA)**
- Uses **asymmetric cryptography**
- Ensures **authentication, integrity, and non-repudiation**
- Standard format, widely compatible

X.509 Certificate Format

An X.509 certificate consists of:

1. **TBS Certificate** (To-Be-Signed data)

2. **Signature Algorithm** (Name of algorithm used)
3. **Signature Value** (Actual signature computed by CA)

How X.509 Works in PKI

1. A user or server generates a key pair.
2. Sends public key + identity to CA.
3. CA verifies identity.
4. CA signs and issues X.509 certificate.
5. Others verify the certificate using CA's public key.

This creates a **chain of trust**.

Applications of X.509 Certificates

- **HTTPS / SSL / TLS** (web security)
- **Digital signatures**
- **Email security (S/MIME)**
- **VPN authentication**
- **Smart cards**
- **IoT device authentication**

Advantages

- Globally accepted standard
- Strong security via CA signatures
- Supports rich extensions
- Scalable for the internet

5. Public key

A **public key** is one half of an asymmetric (public-key) cryptographic key pair.

It is used for **encryption**, **digital signature verification**, and **secure key exchange**.

In asymmetric cryptography, each user has:

1. **Public Key**
 - Shared openly with anyone
 - Used by others to encrypt data or verify signatures
2. **Private Key**
 - Kept secret
 - Used to decrypt data or create signatures

Together, these keys enable secure communication without pre-sharing a secret key.

Functions of a Public Key

1. Encryption

Anyone can encrypt data using the receiver's public key.

Only the corresponding private key holder can decrypt it.

2. Digital Signature Verification

A public key verifies a digital signature created using the sender's private key.

This ensures:

- Authenticity
- Integrity
- Non-repudiation

3. Secure Key Exchange

Used to safely exchange symmetric keys (e.g., in SSL/TLS).

Characteristics of a Public Key

- Publicly available (not confidential)
- Part of a **key pair**

- Mathematically linked to the private key
- Difficult to derive private key from it
- Distributed using:
 - Certificates (X.509)
 - Public key infrastructure (PKI)
 - Public directories
 - Key authorities

Example

If A wants to send a secret message to B:

- A encrypts the message using **B's public key**
- Only B can decrypt it using **B's private key**

Uses of Public Keys

- HTTPS / SSL / TLS
 - Digital Signatures
 - Email Security (PGP, S/MIME)
 - Blockchain and cryptocurrencies
 - Secure messaging apps
 - Authentication systems
-